

TLP: CLEAR

THREAT ACTOR ANALYSIS G0138

Andariel.

A state intelligence operation that pays for itself — ransoming hospitals to fund the theft of submarine, missile and uranium-processing designs, sometimes against the same victim on the same day.

SUBJECT TYPE Threat actor · state	ATTRIBUTION North Korea · RGB 3rd Bureau	FIRST OBSERVED 2009
ASSESSED RISK Critical	REPORT DATE 17 August 2026	IS ACTIVE? Yes

Andariel is a North Korean state intelligence operation that pays for itself. It ransoms hospitals, and spends the proceeds stealing submarine, missile and uranium-enrichment designs — sometimes running both against the same victim on the same day. Since around 2023 it has got in by exploiting unpatched internet-facing web servers rather than by phishing, then held those servers with web shells and worked outward using signed remote-management software as its command channel.

A ransomware incident from this actor is not evidence that espionage is absent. The agencies observed both against one entity on the same day. Scoping an incident as "just ransomware" and closing it after recovery is precisely how the collection half survives the response.

You can calculate your exposure instead of guessing it. The collection requirement is published in unusual detail — autonomous underwater vehicles, phased-array radar, uranium processing, nuclear waste storage. Check your own drawings and bills of materials against that list and you get a real answer.

Two sectors, two different defensive problems. Defence, nuclear and engineering are collection targets and need detection of quiet, long-dwell access. Healthcare is the funding target and needs ransomware resilience. A small number of organisations are both.

The way in changed, so defences tuned to the old one will miss. Phishing awareness was the right control for the group's earlier tradecraft. The primary route is now n-day exploitation of internet-facing servers, which is a patch-latency problem.

Reading a CVE list is not exploiting it. The advisory records more than forty vulnerabilities researched in the National Vulnerability Database. That is reconnaissance. Treating all of them as attributed exploitation would inflate the threat and pull patching priority away from the handful actually named as used.

Espionage that funds itself

Andariel is a North Korean state-sponsored group attributed to the Reconnaissance General Bureau's **3rd Bureau**, based in Pyongyang and Sinuiju, and assessed to be a subset of the Lazarus Group. Vendors track the same actor as Onyx Sleet, Silent Chollima, Stonefly, APT45, DarkSeoul and PLUTONIUM. ¹ ² MITRE dates the group to at least 2009; Microsoft dates its own first observation to 2014. The gap reflects when each organisation began tracking rather than a disagreement about the group. ¹ ³

The defining characteristic is that **the espionage pays for itself**. The group runs ransomware against healthcare entities and uses the proceeds to fund intelligence collection, and the authoring agencies record cases where ransomware and espionage were run against the same entity — in some instances on the same day. ² Most state-sponsored collection is a cost centre; this one is not. That is why a single victim can be hit by two operations that look like completely different actors, and why an incident that opens as a ransomware event may not close as one.

What they are collecting is stated unusually plainly. The advisory lists the requirements: tanks and self-propelled howitzers, littoral combat ships, submarines, torpedoes and autonomous underwater vehicles, fighter aircraft and UAVs, missiles and missile defence, satellites and nano-satellite technology, phased-array radar, uranium processing and enrichment, nuclear waste storage, nuclear power plants, shipbuilding and marine engineering, robotics, additive manufacturing and machining. The material sought is contract specifications, bills of materials, design drawings and engineering documents. ²

Tradecraft has shifted. Historically the group led with spear-phishing; Microsoft records a move to exploiting **n-day vulnerabilities in public-facing web servers** as the primary route in from around 2023, using both public and custom exploits, followed by web shells. Post-access tooling is a large custom RAT family — TigerRAT, SmallTiger, Dora RAT, ValidAlpha, LightHand, DurianBeacon, NukeSped, Atharvan and Goat RAT — packed with Themida and VMProtect, alongside commodity tooling including the Sliver C2 framework, Ngrok, masscan, 3Proxy, PuTTY and Mimikatz, and abuse of legitimate remote monitoring and management software. ² ³

Activity, oldest first

2009

Earliest tracked activity against South Korean targets

MITRE dates the group to at least 2009, operating against South Korean government agencies, military organisations and domestic companies, and against financial institutions including ATMs, banks and cryptocurrency exchanges. Early operations used watering-hole attacks carrying zero-day exploits, spear-phishing attachments, drive-by compromise and ActiveX exploitation, and hid payload code inside PNG and BMP images using steganography. ¹

2020

TigerRAT enters the toolset

The custom TigerRAT backdoor came into use, providing keylogging and screen recording against compromised hosts — capabilities aimed at watching an operator work rather than at moving files in bulk. ³

2021-05

Maui ransomware deployed against healthcare

Maui ransomware was used against US healthcare and public health organisations, encrypting servers responsible for diagnostics, electronic health records and imaging. The proceeds funded intelligence collection, making these victims a *revenue source* rather than a collection target. ⁴

2021-12

Log4Shell exploitation of public-facing web servers

The group began widespread exploitation of internet-facing web servers through known vulnerabilities, with **CVE-2021-44228** in Apache Log4j named as the example, deploying web shells to hold the foothold and reach applications and data behind it. ² ³

2023

N-day exploitation replaces phishing as the primary way in

Microsoft records the group mostly exploiting n-day vulnerabilities from around this point, using publicly available and custom exploits rather than leading with spear-phishing. Named targets include Confluence, PaperCut, TeamCity and Apache ActiveMQ. The group is separately recorded *researching* vulnerabilities in the NIST National Vulnerability Database — reconnaissance, and not evidence that it exploited every CVE it read. ² ³

2023-12

1.2 TB taken from South Korean defence contractors

Microsoft records the theft of 1.2 terabytes of data from South Korean defence contractors, the largest single collection volume attributed to the group in reviewed reporting. ³

2024-02

SmallTiger backdoor identified

A C++ backdoor tracked as SmallTiger was identified, carrying layered obfuscation, and was subsequently used against South Korean defence organisations. It sits alongside TigerRAT rather than replacing it. ³

2024-05

Dora RAT deployed against South Korean organisations

Dora RAT, written in Go, was deployed against South Korean educational institutions, construction companies and manufacturing organisations — a widening of targeting beyond the defence and nuclear core. ³

2024-07-25

Eight-agency joint advisory published

The FBI, CNMF, CISA, DC3, NSA, the Republic of Korea's National Intelligence Service and National Police Agency, and the UK's NCSC published AA24-207A. It sets out the collection requirements in detail and records the group launching ransomware and conducting espionage against the same entity, in some cases on the same day. ²

Two operations, one actor, sometimes one day

Andariel breaks the assumption most triage rests on: that a ransomware incident and a state espionage incident are different problems belonging to different actors with different responses. Here they are the same organisation, funded by the first to perform the second, and the agencies have watched both run against a single victim within a single day. A hospital that pays a ransom may be underwriting the theft of reactor designs from a company it has never heard of, and a defence manufacturer that treats a ransomware alert as a commodity nuisance may be watching the funding arm of the operation that is already inside it.

1 **A ransomware event from this actor is not evidence that espionage is absent.** The agencies observed both against the same entity on the same day. Scoping an incident as "just ransomware" and closing it after recovery is how the collection half survives the response.

2 **The collection requirement is published, so exposure is calculable.** Few actors tell you what they want in this much detail — down to autonomous underwater vehicles, phased-array radar and uranium enrichment. An organisation can check its own drawings and bills of materials against that list and get a real answer rather than a guess.

3 **The way in changed, and defences built for the old one will miss.** Phishing awareness was the right control for the group's earlier tradecraft. Since about 2023 the primary route has been n-day exploitation of internet-facing web servers, which is an exposure-management and patch-latency problem, not a user-training one.

4 **Reading a CVE list is not exploiting it.** The advisory records the group researching dozens of vulnerabilities in the National Vulnerability Database. That is reconnaissance. Treating every CVE on that list as an attributed exploitation would inflate the threat and misdirect patching priority away from the handful actually named as used.

5

Healthcare is exposed for a different reason than everyone else here. It is not on the collection list. It is on the funding list — which means the controls that matter there are ransomware controls, while the controls that matter in defence and nuclear are collection controls. One actor, two defensive problems.

Who this actor actually hits

Two different exposures sit in this table. Most sectors are ranked on whether they hold the technical information the published collection requirements name. Healthcare is ranked on something else entirely — it is the revenue source, not the target.

Defence and aerospace		CRITICAL	The stated collection requirement. The advisory names tanks, submarines, torpedoes, autonomous underwater vehicles, fighter aircraft, UAVs, missiles and satellites individually.
Nuclear		CRITICAL	Named as a collection priority in its own right: uranium processing and enrichment, waste and storage, power plants, and government nuclear research institutes.
Engineering and manufacturing		HIGH	Shipbuilding, marine engineering, robotics, additive manufacturing and machining are all named requirements, and 2024 activity reached South Korean manufacturers directly.
Healthcare		HIGH	Exposed as a ransomware revenue source rather than a collection target — a different threat from the same actor, and the reason espionage against other sectors is funded at all.
Energy		HIGH	Named by Microsoft among the industries of interest to North Korean intelligence that this group targets.
Education and research		MODERATE	South Korean educational institutions were hit in 2024, and research institutes sit adjacent to the nuclear and engineering requirements.

Financial services



MODERATE

Historically targeted — ATMs, banks and cryptocurrency exchanges — but this sits in the group's earlier profile rather than the current collection mandate.

Retail and hospitality



MINIMAL

No indication of interest. Holds neither the technical information the collection requirements name nor the ransomware payout profile of healthcare.

Critical — actively targeted High — fits the victim profile Moderate — plausible, not observed
 Low — outside the pattern Minimal — no indication

Bottom line. Work out which of the two exposures you have, because they need different controls. If your drawings, bills of materials or engineering documents touch anything on the published requirement list, you are a collection target and the priority is detecting quiet, long-dwell access. If you are a healthcare provider, you are a funding target and the priority is ransomware resilience. A small number of organisations are both.

For *how* a compromise actually unfolds — the techniques, the tooling and the order they run in — see the companion attack-flow report, [andariel-G0138-attack-flow.html](#) .

What this analysis is built on

- 1 MITRE ATT&CK — Groups: Andariel (G0138) — <https://attack.mitre.org/groups/G0138/>
- 2 CISA / FBI / CNMF / DC3 / NSA / ROK NIS / ROK NPA / UK NCSC — AA24-207A, North Korea Cyber Group Conducts Global Espionage Campaign to Advance Regime's Military and Nuclear Programs, 25 July 2024 — <https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-207a>
- 3 Microsoft Threat Intelligence — Onyx Sleet uses array of malware to gather intelligence for North Korea, 25 July 2024 — <https://www.microsoft.com/en-us/security/blog/2024/07/25/onyx-sleet-uses-array-of-malware-to-gather-intelligence-for-north-korea/>
- 4 CISA / FBI / Treasury — AA22-187A, North Korean State-Sponsored Cyber Actors Use Maui Ransomware to Target the Healthcare and Public Health Sector — <https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-187a>

Confidence and sourcing. Attribution to the DPRK Reconnaissance General Bureau's 3rd Bureau rests on a joint advisory carrying eight government agencies across three countries, corroborated independently by Microsoft — an unusually strong basis, and stated here as reported rather than assessed. The collection requirements, the same-entity ransomware-and-espionage finding and the tooling names are taken from those two sources directly. Two points of deliberate restraint: the advisory lists more than forty CVEs the group *researched* in the National Vulnerability Database, and this report does not present those as exploited, because the advisory does not; and the 2009 start date follows MITRE while Microsoft dates its own first observation to 2014, which is a difference in tracking history rather than a contradiction. Sector risk levels are analyst assessments, not measured values; they deliberately share a colour ramp with CVSS severity but are rendered as meters rather than scores so the two are not confused.

Pipeline. Step 1 of TI-Reporting. The companion ATT&CK flow report is built from the JSON handoff in `subjects/andariel/handoff/` , of which this analysis produces `analysis.json` .

ATT&CK attack flow

How a compromise unfolds, tactic by tactic and in order. Part 1 established who is at risk and why; this part is how they get hit.

ATTACK FLOW G0138

Andariel.

A collection operation that **pays for itself**. The path below is the espionage programme; one phase in it exists only to fund the rest, by encrypting hospitals. Read the last two cards together — the ransom is not the ending, it is the budget.

ALSO TRACKED AS

Onyx Sleet

Silent Chollima

Stonefly

APT45

DarkSeoul

PLUTONIUM

ATTRIBUTION North Korea · RGB 3rd Bureau	ACTIVE SINCE 2009	OBJECTIVE Espionage
FUNDED BY Ransomware	COLLECTION TARGETS Defence · nuclear	MAPPING Derived

Nine phases, and the ransom is not the last one that matters

Ordered as the operation runs rather than as the matrix lists. One departure is deliberate: the ransomware phase sits *before* the objective, because its proceeds fund the collection that follows. Six tactics carry no techniques and are named in the footer rather than filled in.

01



RESOURCE DEVELOPMENT

Build the toolkit and shop for the way in

- T1587.001** Develop Capabilities: Malware — builds and maintains its own RAT family rather than renting one: [TigerRAT](#), [SmallTiger](#), [Dora RAT](#), [ValidAlpha](#), [LightHand](#), [DurianBeacon](#), [NukeSped](#), [Atharvan](#) and [Goat RAT](#), across C++ and Go and revised over years.
- T1588.002** Obtain Capabilities: Tool — supplements the custom estate with off-the-shelf tooling: [Sliver](#), [Ngrok](#), [masscan](#), [3Proxy](#), [PuTTY](#) and [Mimikatz](#).
- T1588.006** Obtain Capabilities: Vulnerabilities — monitors the NIST National Vulnerability Database for vulnerability information to use in targeting. The advisory records more than forty CVEs researched this way: read, not necessarily exploited.

↓ A shortlist of unpatched products is only useful once one of them is actually reachable from the internet.

02



INITIAL ACCESS

Take the web server, or failing that the reader

- T1190** Exploit Public-Facing Application — exploits n-day vulnerabilities in internet-facing web servers using public and custom exploits. [Log4Shell](#) is the example the advisory names; Confluence, PaperCut, TeamCity and Apache ActiveMQ are the other products recorded. Primary route in from around 2023.
- T1189** Drive-by Compromise — early operations used watering-hole attacks carrying zero-day exploits against South Korean visitors.
- T1566.001** Phishing: Spearphishing Attachment — the group's earlier lead technique, retained rather than retired after the shift to exploitation.

↓ A reachable server or an opened attachment is only a foothold once something runs on it.

03



EXECUTION

Get the first stage running

T1203

Exploitation for Client Execution — exploited **ActiveX** to run code on visitors to compromised sites, the execution half of the watering-hole operations.

T1204.002

User Execution: Malicious File — relies on the recipient opening the spear-phishing attachment to run the first stage.

↓ Code that runs once is worthless to a collection programme without a channel back to the operator.

04



COMMAND AND CONTROL

Four channels, three of them legitimate software

T1071

Application Layer Protocol — runs **Sliver** implants against defence and aerospace targets. Reporting names the framework without specifying the protocol, so this stays at the parent technique.

T1090

Proxy — relays operator traffic through **3Proxy** and other SOCKS proxies.

T1219

Remote Access Tools — abuses legitimate remote monitoring and management software already trusted in the estate, so the operator channel is signed administrative tooling rather than a custom implant.

T1572

Protocol Tunneling — uses **Ngrok** to tunnel out of networks that would not permit an inbound connection.

↓ A channel dies with the process that opened it, so the foothold has to outlive the exploit that created it.

05



PERSISTENCE

Hold the server independently of the exploit

T1505.003

Server Software Component: Web Shell — plants web shells on the exploited web servers to hold the foothold and reach the applications and data behind it, so patching the original flaw does not evict them.

↓ A foothold meant to sit for months has to survive inspection, not just reboot.

06



STEALTH

Make the tooling unreadable rather than the traffic invisible

T1027.002

Obfuscated Files or Information: Software Packing — packs the custom RAT family with the commercial protectors **Themida** and **VMPProtect** before delivery.

T1027.003

Obfuscated Files or Information: Steganography — hid executable payload code inside **PNG** and **BMP** image files in early operations. ATT&CK cites this group by name as a procedure example.

↓ *Hidden and durable, the operation can afford the noisier step of taking credentials.*

07



CREDENTIAL ACCESS

Take the accounts that reach the document stores

T1003

OS Credential Dumping — carries **Mimikatz**. Reporting names the tool without recording which credential store was read on any given intrusion, so this stays at the parent technique rather than asserting LSASS.

↓ *Those same credentials reach two different kinds of server: the ones holding drawings, and the ones a ransom can be charged for.*

08



IMPACT

Encrypt hospitals to pay for the programme

This phase is the funding arm, not the objective. It is placed before the objective deliberately: the proceeds pay for the collection that follows. The agencies record ransomware and espionage run against the same entity, in some cases on the same day.

T1486

Data Encrypted for Impact — deploys **Mau**i ransomware against US healthcare, encrypting servers running diagnostics, electronic health records and imaging.

↓ *The ransom pays for the programme. What follows is what the money is actually for.*



COLLECTION — THE OBJECTIVE

Take the designs the regime asked for

The objective phase carries the Exfiltration icon rather than the struck-through database, because the goal here is theft rather than destruction. The requirement is published in unusual detail: submarines, autonomous underwater vehicles, missiles, phased-array radar, uranium enrichment, nuclear waste storage.

T1005

Data from Local System — took **1.2 TB** from South Korean defence contractors in December 2023. Reporting records the volume rather than the stores it came from, so this is the outcome-level claim that data was taken off compromised systems.

T1056.001

Input Capture: Keylogging — **TigerRAT** logs keystrokes. Placed under Collection rather than Credential Access because the reporting frames the capability as watching an operator work.

T1113

Screen Capture — **TigerRAT** records the screen, which for a mandate built around drawings and design documents returns material a file grab would miss.



Tactic icon and label warm as the operation advances: foothold, then escalation, then the collection objective



The spine tracks the same progression

T####

ATT&CK technique ID

tool.exe

Observed tooling / IOC

Nine backdoors they wrote, and six tools anyone can download

The split is the tell. A group that maintains nine bespoke backdoors across C++ and Go, revised over years, is resourced as a programme rather than a crew — and it still reaches for Mimikatz and Ngrok when those will do.

TigerRAT Custom backdoor providing keylogging and screen recording BACKDOOR	SmallTiger C++ backdoor with layered obfuscation, used against South Korean defence BACKDOOR	Dora RAT Go backdoor used against education, construction and manufacturing BACKDOOR
ValidAlpha Go tool allowing file execution and arbitrary command shells BACKDOOR	LightHand Lightweight backdoor for directory listing and file create/delete BACKDOOR	DurianBeacon RAT used in the November 2023 campaign BACKDOOR
NukeSped Backdoor family named in the joint advisory BACKDOOR	Atharvan Backdoor named in the joint advisory BACKDOOR	Goat RAT Backdoor named in the joint advisory BACKDOOR
Maui Ransomware run against healthcare to fund the espionage operations RANSOMWARE	Sliver Open-source C2 framework used for implants against defence and aerospace C2	Mimikatz Credential dumping CRED ACCESS
Ngrok Tunnelling utility for outbound operator channels TUNNELLING	3Proxy SOCKS proxy for relaying operator traffic TUNNELLING	masscan Mass port scanner held in the toolset DISCOVERY

PuTTY

—

SSH client held in the toolset

TUNNELLING

Themida

—

Commercial protector used to pack
the custom RAT family

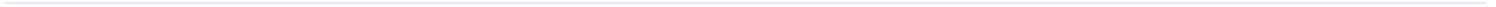
PACKER

VMProtect

—

Commercial protector used to pack
the custom RAT family

PACKER



What this mapping is built on

- 1 MITRE ATT&CK — Groups: Andariel (G0138) — <https://attack.mitre.org/groups/G0138/>
- 2 CISA, FBI and partners — AA24-207A, 25 July 2024 — <https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-207a>
- 3 Microsoft Threat Intelligence — Onyx Sleet uses array of malware to gather intelligence for North Korea — <https://www.microsoft.com/en-us/security/blog/2024/07/25/onyx-sleet-uses-array-of-malware-to-gather-intelligence-for-north-korea/>
- 4 CISA — AA22-187A, Maui ransomware — <https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-187a>

Coverage caveat — read before using this for gap analysis. Six tactics carry no techniques: **Reconnaissance, Privilege Escalation, Defense Impairment, Discovery, Lateral Movement** and **Exfiltration**. That absence reflects what the reviewed reporting documents, not a claim that the group lacks those capabilities — an actor that takes 1.2 TB out of a defence contractor plainly exfiltrates, but no source reviewed here records the route, so no technique is asserted for it.

Provenance. This mapping is *derived* from the vendor and government reporting behind the analysis, not copied from MITRE's published G0138 entry. The two differ substantially: only six of these twenty techniques appear on the MITRE group page, which is narrower because it reflects what MITRE has itself curated. Neither is wrong; they rest on different evidence bases, and this page states which one it used. One deliberate divergence is worth naming: the advisory cites **T1596** for the NVD vulnerability research, but that technique's documented scope is infrastructure databases — DNS, WHOIS, certificates — so this mapping uses **T1588.006**, which names the National Vulnerability Database explicitly. Built from the JSON handoff in [subjects/andariel/handoff/](#).

Ordered by the phases of Part 2, not by general best practice — each item names the mapped technique it denies. This actor exploits no CVE central enough to carry a patch table, so there is no remediation section in Part 2 and these priorities take its place.

1. Patch internet-facing applications on a cadence measured in days, and inventory what is actually exposed first.

Denies T1190, the primary route in since 2023. The group monitors the National Vulnerability Database for candidates (T1588.006), so the window between a fix shipping and yours landing is the window it works in.

2. Hunt for web shells on every internet-facing server, and do it separately from patching.

Denies T1505.003. The web shell survives the patch that closed the way in, so an estate that patched and did not hunt has closed the door behind the operator rather than in front of them.

3. Allowlist remote monitoring and management software, and alert on any instance outside that list.

Denies T1219. The operator channel here is signed, legitimate administrative tooling, so it will not trip malware detection — only an inventory of what is authorised will surface it.

4. Control egress and alert on tunnelling from servers that have no reason to originate outbound sessions.

Denies T1572 and T1090. Ngrok and SOCKS proxies exist to defeat the assumption that a server behind a firewall cannot be reached; a web server initiating outbound tunnels is the signal.

5. Tier administrative credentials and protect LSASS, so one compromised server does not yield the document stores.

Denies T1003. Credential access is the hinge in this flow: it is what turns a single exploited web server into reach across both the design repositories and the servers a ransom can be charged for.

6. Monitor access to design repositories, and treat bulk reads of drawings and bills of materials as an alertable event.

Denies T1005, T1113 and T1056.001 — the objective phase. 1.2 TB left a set of defence contractors in one recorded case, and screen capture returns material that file-level controls never see.

7. If you are a healthcare provider, hold offline or immutable backups outside domain trust.

Denies T1486. Your exposure to this actor is the funding operation rather than the collection one, so ransomware resilience is the control that matters and the collection guidance above largely does not apply to you.